

Advisory - Certighost Vulnerability (CVE 2026-54121)

Severity – High

CVSS – 8.8

CWE – Improper Authorization

Executive Summary

Microsoft has released security updates to address CVE-2026-54121, an Active Directory Certificate Services (AD CS) vulnerability known as “Certighost.” The flaw affects vulnerable Enterprise Certificate Authority deployments and may allow a low-privileged, authenticated domain user to obtain a valid certificate representing a Domain Controller without requiring administrative privileges or user interaction.

The vulnerability exists in the AD CS certificate-enrollment chase fallback mechanism. During certificate processing, a vulnerable Certificate Authority may trust a requester-supplied directory server without first confirming that it is a legitimate Domain Controller. An attacker can abuse this behavior by directing the CA to an attacker-controlled SMB and LDAP service, returning identity information associated with a real Domain Controller, and causing the legitimate CA to issue a trusted certificate containing the Domain Controller’s identity.

The attacker may then use the fraudulently issued certificate through Kerberos PKINIT to authenticate as the Domain Controller. This access can potentially enable DCSync activity, allowing the extraction of sensitive Active Directory credentials, including the krbtgt account secret. Compromise of the krbtgt secret may support Golden Ticket creation, long-term persistence, privilege escalation, lateral movement, ransomware deployment, and domain-wide compromise.

Vulnerability Description

CVE-2026-54121, also known as Certighost, is a high-severity improper authorization vulnerability (CWE-285) affecting Microsoft Active Directory Certificate Services (AD CS). It has a CVSS 3.1 score of 8.8 and may allow a low-privileged, authenticated domain user to elevate privileges remotely without requiring administrator access or user interaction.

The vulnerability affects vulnerable Enterprise Certificate Authority (CA) servers responsible for issuing trusted certificates to users, computers, and Domain Controllers in an Active Directory environment. Because these certificates can be used for authentication, improper validation during certificate issuance can allow an attacker to impersonate a highly privileged domain system.

The flaw exists in the AD CS certificate enrollment chase fallback mechanism. This mechanism is triggered when the CA cannot directly resolve the identity associated with a certificate request. During the fallback process, the CA may use requester-controlled `cdc` and `rmd` attributes to determine which directory server to contact and which machine identity to resolve.

In vulnerable systems, the CA does not properly verify that the directory server specified in the request is a genuine and authorized Domain Controller. An attacker can create or control a machine account, operate rogue SMB and LDAP services, and submit a specially crafted certificate request that directs the CA to the attacker-controlled system.

When the fallback chase is triggered, the CA connects to the rogue server and requests directory information. The attacker-controlled service responds with identity attributes belonging to a legitimate Domain Controller, including its `objectSID` and `dNSHostName`. Because the vulnerable CA fails to correctly validate the source and relationship of this information, it may issue a certificate containing the Domain Controller's identity.

The resulting certificate is signed by the organization's legitimate Enterprise CA, while the attacker controls the associated private key. This means the certificate appears cryptographically valid and trusted even though it was issued to an unauthorized requester.

The attacker can then use the certificate with Kerberos PKINIT to authenticate as the targeted Domain Controller. Since Domain Controller accounts possess Active Directory

replication privileges, the attacker may perform a DCSync operation to retrieve sensitive password-derived information, including the krbtgt account secret.

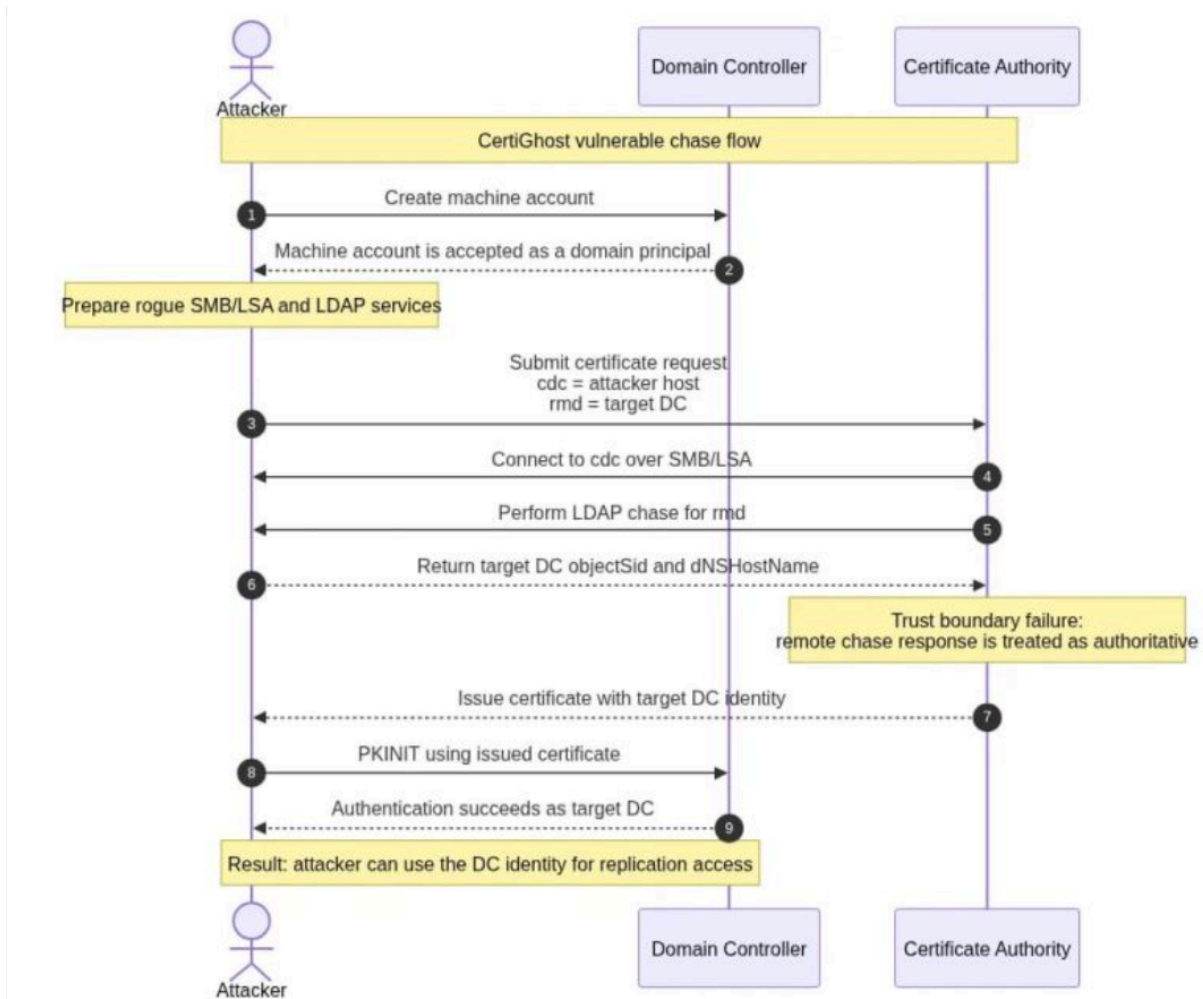
Successful exploitation may result in Domain Controller impersonation, unauthorized certificate issuance, credential theft, privilege escalation, lateral movement, persistent access, Golden Ticket creation, ransomware deployment, and complete Active Directory domain compromise. The publicly documented research demonstrates how a low-privileged domain identity could be escalated to Domain Controller impersonation under vulnerable conditions.

Microsoft addressed the vulnerability in its July 14, 2026 security updates by strengthening validation in the chase process. The patched CA verifies that the supplied directory server is a legitimate Domain Controller and checks its identity before accepting returned directory information or issuing a certificate.

Terminology -

1. Fallback Chase - A backup process AD CS uses when it cannot directly resolve a requester's identity.
- 2.cdc - Identifies the directory server the CA should contact during the chase process.
- 3.rmd - Contains machine information used during certificate identity resolution.
- 4.PKINIT - Kerberos authentication using trusted digital certificates instead of passwords.
- 5.DCSync - An attack that abuses replication privileges to retrieve Active Directory credentials.

Attack Flow Diagram →



POTENTIAL IMPACT

Successful exploitation of CVE-2026-54121 may allow a low-privileged authenticated domain user to escalate privileges and impersonate a Domain Controller by obtaining a trusted certificate issued by the organization's Enterprise CA .

- **Active Directory credential theft:** The attacker may abuse directory replication privileges through DCSync to retrieve password hashes and sensitive account secrets.
- **Domain Controller impersonation:** The attacker may authenticate as a trusted Domain Controller using the fraudulently issued certificate.
- **KRBTGT account compromise:** Theft of the KRBTGT secret may allow the attacker to forge Kerberos authentication tickets.
- **Golden Ticket creation:** Forged Kerberos tickets may provide long-term, privileged access across the domain.
- **Privilege escalation:** A standard domain account may be elevated to highly privileged domain-level access.
- **Lateral movement:** The attacker may access additional servers, endpoints, file shares, applications, and administrative systems.
- **Persistent access:** Stolen credentials, forged tickets, or unauthorized certificates may be used to maintain access even after the initially compromised account is disabled.
- **Security-control manipulation:** The attacker may disable monitoring tools, modify Group Policy, create privileged accounts, or weaken domain security settings.
- **Sensitive-data exposure:** Business records, employee information, credentials, intellectual property, and other protected data may be accessed or exfiltrated.
- **Malware or ransomware deployment:** Domain-level privileges may allow malicious software to be distributed across systems.
- **Full Active Directory compromise:** In a successful end-to-end attack, the attacker may gain extensive control over the affected domain and its connected resources.

Recommended Action (Patch Info)

1. Patch all Enterprise CA servers.

Identify every server running the Active Directory Certificate Services Certification Authority role:

Command -

```
Get-WindowsFeature ADCS-Cert-Authority
```

Install Microsoft's July 14, 2026 security update or a later cumulative update on every Enterprise CA server, then restart the system.

2. Disable the chase mechanism temporarily.

Use this only when immediate patching is not possible, and test it in a non-production CA first.

Disabling Command -

```
certutil -setreg policy\EditFlags -EDITF_ENABLECHASECLIENTDC
```

Restarting Services - `Restart-Service CertSvc -Force`

3. Restrict computer-account creation.

Reduce machine-account creation exposure by audit and, where feasible, lower ms-DS-MachineAccountQuota from its default value of 10 to limit the ability of low-privileged users to create computer accounts usable in this attack chain.

Step 1: Audit the current Machine Account Quota

Command -

```
Get-ADDomain | Select-Object DNSRoot, ms-DS-MachineAccountQuota
```

Step 2: Reduce the Machine Account Quota

Command -

```
Set-ADDomain -Identity "example.com" -Replace @{
```

```
'ms-DS-MachineAccountQuota' = 0
```

```
}
```

4. Hunt for prior abuse

Checking whether attackers exploited Certifhost before the AD CS servers were patched
Open the Certification Authority console -

Command - `certsrv.msc`

Go To - Certification Authority → Your CA → Issued Certificates

To check and review certificate requests from the suspected exposure period.

5. Monitor Network Paths to CA Infrastructure

Alert on unexpected outbound SMB (445) and LDAP (389) connections from CA servers to non-Domain-Controller hosts, which would indicate an in-progress chase-abuse attempt.

Monitor outbound SMB and LDAP traffic from the CA

On the CA server, enable Windows Firewall logging:

Command -

```
Set-NetFirewallProfile -Profile Domain -LogAllowed True -LogBlocked True
```

Step 2: Restrict CA communication to Domain Controllers only.

Create Windows Firewall rules to allow LDAP/SMB only to trusted Domain Controllers and block all other destinations.

Command -

```
New-NetFirewallRule -DisplayName "Allow LDAP to DC" -Direction Outbound -Protocol TCP -RemotePort 389 -RemoteAddress <DC-IP> -Action Allow
```

```
New-NetFirewallRule -DisplayName "Allow SMB to DC" -Direction Outbound -Protocol TCP -RemotePort 445 -RemoteAddress <DC-IP> -Action Allow
```

6. Review certificate template permissions

Confirm which security principals can enroll in the default Machine template and other sensitive templates, and tighten ACLs where enrollment rights exceed operational need.

Step 1: Review template permissions

Command - `certtmpl.msc`

Review the Machine, Computer, Domain Controller, and other sensitive templates.

Check the Security tab to identify which users or groups have Enroll or Autoenroll permissions.

Step 2: Restrict unnecessary enrollment rights

Remove Enroll and Autoenroll permissions from unnecessary groups (e.g., Authenticated Users or Domain Users) and allow enrollment only for authorized computers, Domain Controllers, or designated administrative groups.

References

1. <https://www.dataminr.com/resources/intel-brief/certighost-cve-2026-54121/>
2. <https://gist.github.com/H0j3n/a5ef2609b5f2944ac2390a191a534c26>
3. <https://kb.gajshield.com/a/1134/new-certighost-poc-exploit-lets-attackers-hijack-windows-domains>
4. <https://socprime.com/active-threats/certighost-active-directory-certificate-services-adcs-vulnerability-cve-2026-54121/>
5. <https://www.youtube.com/watch?v=8kpZyrsDWJk>

